

ISO 27001 Certification Checklist for UK SMEs

Rob Pragnell | CQI/IRCA Certified Lead Auditor — ISO 27001 | Anacruses Associates Ltd | anacruses.co.uk

How to use this checklist

Work through each section before your Stage 2 certification audit. Every item marked **Required** must be evidenced — not just documented, but demonstrably operating. Items marked **Recommended** are best practice that auditors will look for but may not raise as nonconformities if absent. Tick each box as you confirm it is in place.

1. Scope and Context

Item	Status	✓
Organisational context documented Internal and external issues relevant to the ISMS scope are identified and documented (Clause 4.1).	Required	☐
Interested parties identified Stakeholders with requirements relevant to information security are listed with their specific requirements (Clause 4.2).	Required	☐
ISMS scope formally defined The scope document states which organisational units, locations, assets, and processes are included and excluded, with justification for exclusions (Clause 4.3).	Required	☐
Scope matches operational reality The certified scope accurately reflects what the organisation actually does — remote workers, cloud systems, and outsourced functions are accounted for.	Required	☐

2. Leadership and Policy

Item	Status	✓
Information security policy approved and signed Policy is signed by top management, dated, and communicated to all relevant staff. Must reference commitment to continual improvement (Clause 5.2).	Required	■
Information security roles and responsibilities assigned Named individuals are responsible for the ISMS. Responsibilities are documented and communicated (Clause 5.3).	Required	■
Management review conducted and minuted At least one formal management review has taken place, covering the inputs required by Clause 9.3, with minutes retained as evidence.	Required	■
Top management able to demonstrate involvement Auditors will interview senior leadership. They must be able to speak to the ISMS without being coached.	Required	■

3. Risk Assessment and Treatment

Item	Status	✓
Risk assessment methodology documented A formal methodology for identifying, analysing, and evaluating information security risks is documented and approved (Clause 6.1.2).	Required	■
Risk register completed All information assets within scope have been assessed. Risks are recorded with likelihood, impact, and risk level scores.	Required	■
Risk treatment plan completed Each identified risk has a documented treatment decision — accept, mitigate, transfer, or avoid — with planned actions and owners.	Required	■
Risk treatment plan implemented Treatment actions are not just planned — they are evidenced as complete or in progress with a documented schedule.	Required	■
Risk assessment reviewed within last 12 months The risk assessment must be kept current. New assets, threats, or changes to the organisation must be reflected.	Required	■
Risk owners identified Each risk has a named owner who is accountable for the treatment decision.	Required	■

4. Statement of Applicability

Item	Status	✓
SoA covers all 93 Annex A controls Every control in ISO 27001:2022 Annex A is listed with an applicability decision and justification for inclusion or exclusion.	Required	■
Excluded controls have documented justification Controls marked as not applicable must have a clear, auditable reason. "Not relevant" is not sufficient — the risk basis must be stated.	Required	■
SoA cross-references risk treatment plan The SoA should reference where each applicable control is implemented — in a specific policy, procedure, or technical measure.	Required	■
SoA approved by management The SoA must be formally approved, dated, and version-controlled.	Required	■
SoA implementation status current The SoA should reflect the current implementation status of each applicable control, not just the intended status.	Recommended	■

5. Controls and Documentation

Item	Status	✓
Information security policy suite complete Policies covering access control, acceptable use, clear desk/screen, information classification, incident management, and supplier security are in place.	Required	■
Access control implemented and evidenced User access rights are documented, access is granted on a least-privilege basis, and access reviews are conducted and recorded.	Required	■
Asset inventory maintained All information assets within scope are listed with owners, classifications, and handling requirements.	Required	■
Supplier security assessments conducted Cloud providers, SaaS platforms, outsourced IT, and other suppliers handling your data have been assessed for information security controls (Annex A 5.19–5.22).	Required	■
Incident response procedure documented and tested A documented procedure exists for detecting, reporting, and responding to information security incidents. At minimum, a tabletop exercise has been conducted.	Required	■
Business continuity and backup controls in place Backup procedures are documented, backups are tested, and recovery time objectives are defined (Annex A 8.13, 5.29–5.30).	Required	■
Encryption policy implemented A policy on the use of cryptographic controls exists. Encryption of data at rest and in transit is implemented where required by the risk assessment (Annex A 8.24).	Required	■
Physical security controls evidenced Physical security perimeters, entry controls, and equipment security measures are documented and operating.	Required	■
Patch management and vulnerability process in place A process for managing technical vulnerabilities and applying security patches is documented and evidenced (Annex A 8.8).	Required	■
Security awareness training conducted All staff have received information security awareness training. Records of attendance are retained (Annex A 6.3).	Required	■
Threat intelligence process in place A process for collecting and acting on information security threat intelligence is documented (Annex A 5.7 — new in 2022).	Recommended	■
Data masking and anonymisation considered Where personal or sensitive data is processed, data masking controls have been assessed and implemented where appropriate (Annex A 8.11 — new in 2022).	Recommended	■

6. Internal Audit

Item	Status	✓
Internal audit programme documented A documented audit programme covering all ISMS processes and Annex A controls over a defined period is in place (Clause 9.2).	Required	■
Internal audit conducted At least one complete internal audit cycle has been completed before the Stage 2 audit, with results documented.	Required	■
Audit findings addressed All nonconformities identified during internal audit have corrective actions assigned, with target dates and evidence of completion or progress.	Required	■
Internal auditors are objective and impartial Internal auditors do not audit their own work. Independence is documented.	Required	■

7. Performance and Continual Improvement

Item	Status	✓
Information security objectives set and monitored Measurable objectives are documented with plans for achieving them. Progress is monitored and results are available (Clause 6.2).	Required	■
KPIs or metrics collected Quantitative measures of ISMS performance — such as number of incidents, patch compliance rate, or access review completion — are tracked.	Recommended	■
Nonconformity and corrective action process operating A process for logging, investigating, and resolving nonconformities is documented and evidenced with records (Clause 10.1).	Required	■
Continual improvement documented Evidence of at least one improvement to the ISMS based on audit results, incidents, or management review is available (Clause 10.2).	Required	■

The five most common reasons UK businesses fail their ISO 27001 Stage 2 audit

1. Statement of Applicability lists controls as applicable but no evidence of implementation exists.
2. Risk treatment plan completed but risks have not actually been treated — actions are still pending.
3. No supplier security assessment process — cloud and SaaS providers used without documented review.
4. Internal audit conducted too superficially — policies checked but operational controls not tested.
5. Scope on the certificate does not match operational reality — remote workers or systems excluded incorrectly.

Need help getting ISO 27001 certified?

Anacruses Associates provides fixed-fee ISO 27001 consultancy for UK businesses — from gap analysis through to certification audit support. Every client works directly with Rob Pragnell, CQI/IRCA certified Lead Auditor.

Book a free consultation

anacruses.co.uk/contact

Call

07792 259840

Email

assurance@anacruses.co.uk